# Instituicao de Ensino Demo

**Curso: Engenharia de Software**

**5o Semestre**

# Material de Estudo

## Seguranca da Informacao

---

### 1. INTRODUCAO

A Seguranca da Informacao e uma area critica na engenharia de software. Com o aumento de ataques ciberneticos e vazamentos de dados, proteger sistemas e informacoes e uma responsabilidade de todo desenvolvedor. Esta disciplina aborda desde criptografia e autenticacao ate vulnerabilidades comuns e conformidade legal (LGPD). Entender seguranca nao e opcional — e uma competencia essencial para construir software confiavel e proteger usuarios.

**Ementa:** Principios de seguranca (CIA). Criptografia simetrica e assimetrica. Autenticacao e controle de acesso. Vulnerabilidades e ataques comuns (OWASP). Seguranca em redes. Seguranca em aplicacoes web. Gestao de riscos. Conformidade e LGPD.

## 2. CONCEITOS FUNDAMENTAIS

A seguir, apresentamos os conceitos-chave desta disciplina com explicacoes didaticas e exemplos praticos para facilitar o aprendizado.

### *2.1 Triade CIA e Criptografia*

A triade CIA define os tres pilares da seguranca: Confidencialidade (apenas autorizados acessam), Integridade (dados nao sao alterados indevidamente) e Disponibilidade (sistema acessivel quando necessario). Criptografia simetrica (AES) usa a mesma chave para cifrar e decifrar. Criptografia assimetrica (RSA) usa par de chaves publica/privada. Hashing (SHA-256) gera resumo irreversivel.

**Exemplo:**

```
Criptografia simetrica (AES):
Chave: "minha-chave-secreta"
Texto: "dados sensiveis" -> cifrar -> "x7f2a9..."
Mesma chave para decifrar.

Criptografia assimetrica (RSA):
Chave publica: cifra (qualquer um pode cifrar)
Chave privada: decifra (so o dono pode ler)

Hash SHA-256:
"senha123" -> "ef92b778bafe771e89245b89ecbc08a44a4e166c..."
```

### *2.2 OWASP Top 10 e Seguranca Web*

O OWASP Top 10 lista as vulnerabilidades mais criticas em aplicacoes web. SQL Injection permite executar comandos SQL maliciosos. XSS (Cross-Site Scripting) injeta scripts no navegador do usuario. CSRF forca acoes nao autorizadas. Prevencao inclui: validacao de entrada, queries parametrizadas, tokens CSRF, Content Security Policy e sanitizacao de saida.

**Exemplo:**

```
SQL Injection - VULNERAVEL:
query = f"SELECT * FROM users WHERE name='{input}'"
Input malicioso: ' OR 1=1 --

SEGURO (query parametrizada):
cursor.execute("SELECT * FROM users WHERE name=?", (input,))

XSS - VULNERAVEL:
document.innerHTML = userInput

```

```
SEGURO:
```

```
document.textContent = userInput
```

## 3. RESUMO DOS PRINCIPAIS TOPICOS

O conteudo programatico da disciplina esta organizado nas seguintes unidades:

- Unidade 1: Principios de seguranca - Confidencialidade, Integridade, Disponibilidade
- Unidade 2: Criptografia simetrica (AES) e assimetrica (RSA)
- Unidade 3: Hashing, assinaturas digitais e certificados
- Unidade 4: Autenticacao, autorizacao e controle de acesso (RBAC, OAuth)
- Unidade 5: Vulnerabilidades web - OWASP Top 10 (SQL Injection, XSS, CSRF)
- Unidade 6: Seguranca em redes - firewalls, IDS/IPS, VPN
- Unidade 7: Gestao de riscos e resposta a incidentes
- Unidade 8: Conformidade, LGPD e normas (ISO 27001)

Cada unidade aborda um aspecto fundamental da disciplina, construindo progressivamente o conhecimento necessario para dominar o tema. Recomenda-se estudar as unidades na ordem apresentada.

## 4. EXERCICIOS DE FIXACAO

Resolva os exercicios abaixo para verificar seu entendimento dos conceitos apresentados.

### **Questao 1** (Multipla Escolha)

Qual pilar da triade CIA garante que dados nao sejam alterados indevidamente?

a) Confidencialidade
b) Integridade
c) Disponibilidade
d) Autenticidade

### **Questao 2** (Dissertativa)

Explique a diferenca entre criptografia simetrica e assimetrica. Quando usar cada uma?

### **Questao 3** (Multipla Escolha)

Qual vulnerabilidade permite executar comandos SQL maliciosos no banco de dados?

a) XSS
b) CSRF
c) SQL Injection
d) Buffer Overflow

### **Questao 4** (Dissertativa)

Descreva 3 medidas praticas que um desenvolvedor deve adotar para prevenir vulnerabilidades do OWASP Top 10.

## 5. DICAS DE ESTUDO E RECURSOS ADICIONAIS

Para maximizar seu aprendizado nesta disciplina, siga estas recomendacoes:

- Estude o OWASP Top 10 e pratique identificando vulnerabilidades.
- Use ferramentas como Burp Suite e OWASP ZAP para testes de seguranca.
- Aprenda sobre LGPD — e obrigatorio para sistemas que tratam dados pessoais no Brasil.
- Pratique criptografia com bibliotecas como cryptography (Python).
- Participe de CTFs (Capture The Flag) para aprender seguranca na pratica.

**Bibliografia Recomendada:**


- STALLINGS, W. Criptografia e Seguranca de Redes. Pearson, 2015.
- TANENBAUM, A. Redes de Computadores. Pearson, 2011.
- OWASP Foundation. OWASP Top 10 - 2021. owasp.org.

## 6. GLOSSARIO DE TERMOS IMPORTANTES

Consulte este glossario sempre que encontrar um termo desconhecido durante seus estudos.

- **CIA**: Confidencialidade, Integridade, Disponibilidade — pilares da seguranca.
- **Criptografia simetrica**: mesma chave para cifrar e decifrar (ex: AES).
- **Criptografia assimetrica**: par de chaves publica/privada (ex: RSA).
- **Hash**: funcao que gera resumo de tamanho fixo (irreversivel).
- **SQL Injection**: ataque que injeta comandos SQL maliciosos.
- **XSS**: Cross-Site Scripting — injeta scripts no navegador.
- **LGPD**: Lei Geral de Protecao de Dados Pessoais.
- **OWASP**: Open Web Application Security Project.
- **Firewall**: dispositivo que filtra trafego de rede.